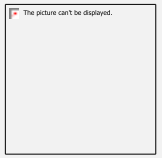
Information Security CSC232

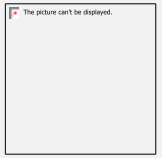
LECTURE-2 14-SEPT-2026

SAAD MALIK

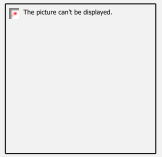
Contents:



Part 1: IS Components



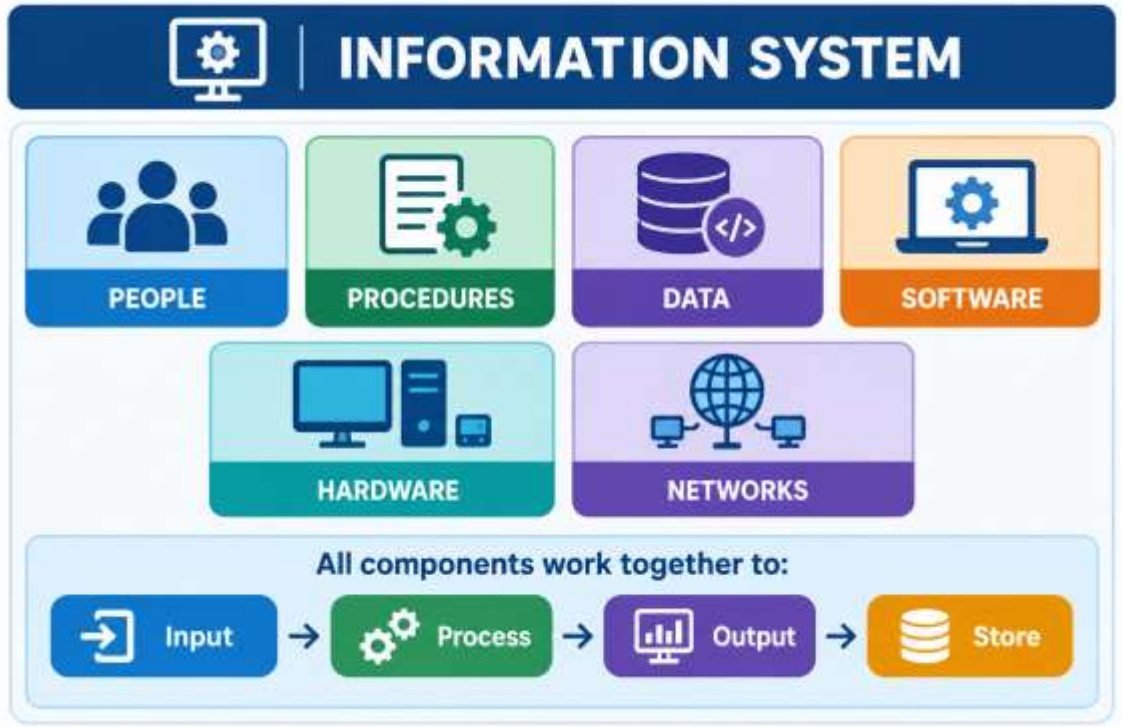
Part 2: Design Principles



Part 3: Threats and Attacks

The Information System - An Overview

An information system (IS) is much more than computer hardware; it is the entire set of software, hardware, data, people, procedures, and networks that make possible the use of information resources in the organization.“



Component 1 — People

Why People Matter:

- **The weakest link** in security
- Can be **insiders** (employees, contractors) or **outsiders** (hackers, competitors)
- Social engineering targets people, not machines

Categories of People:

Category	Description	Examples
Employees	Trusted insiders with access	Managers, developers, DBAs
Nonemployees	External parties with limited access	Contractors, consultants, vendors
Strangers	Unknown individuals	Visitors, job applicants

Real-World Example:

The Genghis Khan Story

- Chinese emperor built the Great Wall to stop invaders
- Genghis Khan's army couldn't climb over or dig under
- **Solution:** He bribed the gatekeepers and local commanders
- **Moral:** People can bypass any technical control

People — Security Implications

Managing the Human Factor

Key Security Measures:

1. **Background Checks** — Verify identity and history
2. **Security Awareness Training** — Teach employees to recognize threats
3. **Role-Based Access** — Only give access needed for the job
4. **Separation of Duties** — No single person has complete control
5. **Mandatory Vacations** — Detect ongoing fraud
6. **Exit Procedures** — Revoke access immediately upon termination

Real-World Example:

The Disgruntled Employee

1. An IT administrator was terminated
2. Their access was not revoked immediately
3. They logged in from home and deleted critical files
4. **Cost:** $1 million in recovery and lost productivity
5. **Lesson:** Immediate access revocation is essential

Component 2 — Procedures (Processes)

What are Procedures?

- **Written instructions** for accomplishing a specific task
- Define **how** things should be done
- Include **policies, standards, and guidelines**

Why Procedures Matter:

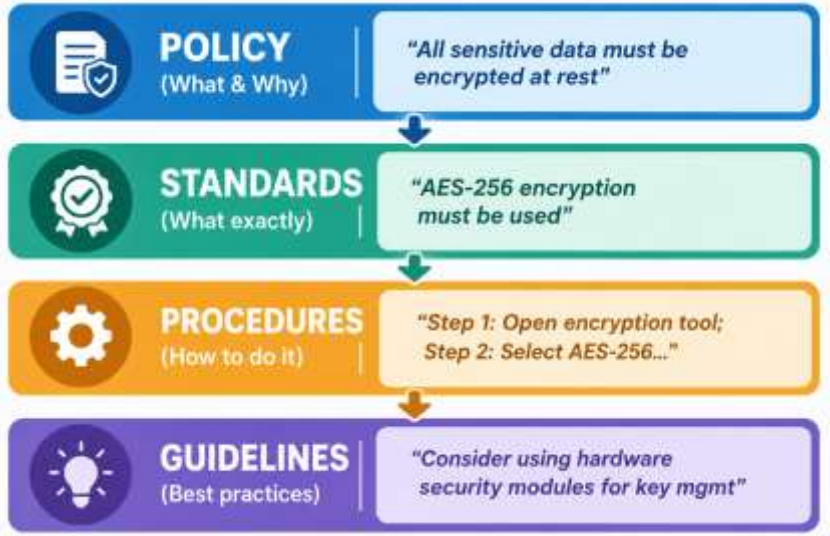
- Ensure **consistency** across the organization
- Provide **accountability** and **traceability**
- Enable **auditing** and **compliance**

Real-World Example:
The Bank Wire Transfer Incident

- A consultant learned how to wire funds by reading readily available procedures
- The bank lacked authentication controls
- The consultant ordered **$10 million** to be wired to his own account
- **Lesson:** Procedures are information in their own right and must be protected

Component 2 — Procedures (Processes)

- ▶Real-World Example:
- ▶Equifax Breach (2017)
- ▶147 million records exposed
- ▶Root cause: Procedures for patching known vulnerabilities were not followed
- ▶Apache Struts vulnerability was identified in March 2017
- ▶Patch was available but not applied
- ▶Cost: $1.4 billion+



Component 3 — Data

The Most Valuable Asset

Why Data is Critical:

- **Main target** of intentional attacks
- **Drives business decisions**
- **Contains intellectual property**
- **Subject to legal and regulatory requirements**

Data States:

State	Description	Security Measures
Storage	Data at rest	Encryption, access controls
Transmission	Data in motion	TLS, VPNs, encryption
Processing	Data in use	Memory protection, access controls

Data Classification:

- **Confidential** — Strictly controlled (e.g., trade secrets)
- **Internal** — Company use only
- **Public** — Approved for public release

Data — Real-World Breaches

Notable Data Breaches
1. Yahoo (2013-2014)
3 billion accounts compromised
Names, emails, passwords, security questions
Cost: $350 million reduction in acquisition price

2. Marriott/Starwood (2018)
500 million guest records exposed
Passport numbers, credit card data
Cost: $124 million fine

3. Facebook/Cambridge Analytica (2018)
87 million users' data harvested
Used for political advertising
Cost: $5 billion FTC fine

4. Equifax (2017)
147 million consumers
Social Security numbers, birth dates, addresses
Cost: $1.4 billion+

Lesson: Data is the crown jewel — protect it accordingly

Component 4 — Software

Applications, Operating Systems, and Utilities

Why Software is Difficult to Secure:

- **Complexity** — Millions of lines of code
- **Bugs and vulnerabilities** — Inevitable in large systems
- **Third-party components** — Supply chain risks
- **Time-to-market pressure** — Security as afterthought

Types of Software:

Type	Examples	Security Concerns
Operating Systems	Windows, Linux, macOS	Kernel vulnerabilities, privilege escalation
Applications	Office, browsers, ERP	Buffer overflows, injection attacks
Utilities	Antivirus, backup tools	Configuration errors, false positives
Security Components	Firewalls, IDPS	Misconfiguration, bypass

Software — Real-World Vulnerabilities

- 1. Heartbleed (2014)
- Vulnerability: OpenSSL buffer over-read
- Impact: Allowed reading of server memory
- Affected: ~17% of all secure web servers
- Data exposed: Passwords, credit cards, private keys

- 2. WannaCry (2017)
- Vulnerability: Windows SMB protocol
- Impact: Ransomware encrypted files
- Affected: 200,000+ computers in 150 countries
- Cost: $4 billion+ globally

- 3. Log4Shell (2021)
- Vulnerability: Log4j logging library
- Impact: Remote code execution
- Affected: Millions of Java applications
- Severity: 10.0 (maximum)

- 4. SolarWinds (2020)
- Vulnerability: Supply chain compromise
- Impact: Backdoor in software updates
- Affected: 18,000+ customers including US government
- Lesson: Trust in software supply chain is critical

Component 5 — Hardware

What Hardware Includes:

- **Servers and mainframes**
- **Desktop and laptop computers**
- **Mobile devices** (smartphones, tablets)
- **Networking equipment** (routers, switches)
- **Storage devices** (hard drives, tapes, USB)
- **Security devices** (firewalls, IDPS appliances)

Physical Security Threats:

Threat	Description	Example
Theft	Physical removal	Laptop stolen from airport
Damage	Accidental or intentional	Coffee spilled on server
Environmental	Heat, humidity, dust	Server room AC failure
Surveillance	Shoulder surfing	Reading screen from distance
Tampering	Hardware modification	Keylogger installed

Hardware — Real-World Incidents

- Hardware Security Incidents

- 1. Laptop Theft at Airports
- Pre-9/11: Two-person teams stole laptops at security checkpoints
- Method: One distracted, one grabbed
- Impact: Corporate data, credentials, intellectual property
- Lesson: Physical security is as important as logical security

- 2. USB Drop Attack
- Scenario: USB drives left in parking lots
- Result: 45% of drives picked up and plugged in (University of Illinois study)
- Impact: Malware installation, data exfiltration

- 3. Rogue Device
- Scenario: Unauthorized Raspberry Pi connected to network
- Purpose: Man-in-the-middle attacks
- Detection: Network monitoring, physical inspection

- 4. Server Room Flood
- Scenario: Pipe burst above server room
- Impact: $500,000 in equipment damage
- Lesson: Environmental controls and water detection are essential

Component 6 — Networks

What Networks Enable:

Resource sharing (files, printers, applications)

Communication (email, instant messaging)

E-commerce and online services

Remote access and telecommuting

Network Types:

Type	Scope	Example
LAN	Local	Office building
WAN	Wide area	Across cities/countries
MAN	Metropolitan	City-wide
PAN	Personal	Bluetooth devices

Network Security Challenges:

Eavesdropping — Sniffing network traffic

Spoofing — Forging source addresses

Interception — Man-in-the-middle

Denial of Service — Flooding with traffic

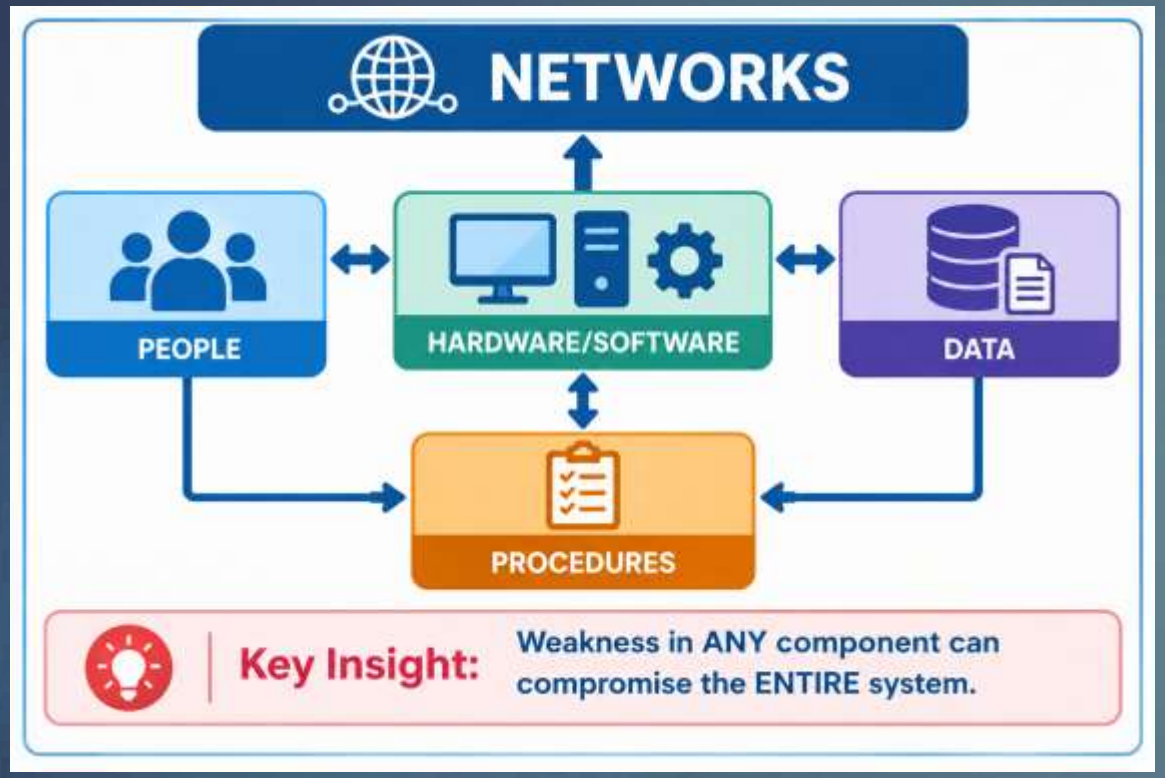
Unauthorized Access — Breaking into systems

Networks — Real-World Attacks

- 1. Mafiaboy (2000)
- Target: Amazon, CNN, eBay, Yahoo, Dell
- Method: Distributed Denial of Service (DDoS)
- Impact: Millions in lost revenue
- Attacker: 15-year-old Canadian
- Lesson: Even unsophisticated attackers can cause massive damage

- 2. ARPANET Insecurity
- Era: 1970s
- Problem: Phone numbers publicly posted, no authentication
- Result: Hackers easily accessed military networks
- Lesson: Security must be designed into networks from the start

- 3. Network Sniffing
- Scenario: Attacker installs packet sniffer on network
- Impact: Captures passwords, emails, sensitive data
- Detection: Hard to detect — passive monitoring
- Prevention: Encryption, switched networks



The Six Components — Working Together

Design Principle 1 — Least Privilege

Definition:

"Every program and every user of the system should operate using the least set of privileges necessary to complete the job."
— Saltzer & Schroeder (1975)

Key Concepts:

- **Need-to-know basis** — Access only required information
- **Minimal time** — Access only for required duration
- **Minimal scope** — Access only required resources

Real-World Example:

The Overprivileged Developer

- Scenario: A developer had full database administrator rights
- Problem: Could read, modify, or delete ANY data
- Risk: Accidental or intentional damage
- **Solution:** Give developers only the access needed for their tasks
- **Result:** Reduced risk of data loss by 80%

Least Privilege — Implementation

Putting Least Privilege into Practice

Area	Bad Practice	Good Practice
User Accounts	Admin rights for everyone	Standard users, separate admin accounts
Database Access	Full table access	Row-level, column-level access
File Permissions	Everyone can read/write	Role-based access controls
Network Access	Open internal network	Segmentation, firewall rules
Application Access	All features enabled	Feature-level permissions

Real-World Example:

Target Breach (2013)

- Attackers stole credentials from a third-party HVAC vendor
- Vendor had network access for billing and project management
- No segmentation between vendor access and payment systems
- **Impact:** 40 million credit card numbers stolen
- **Lesson:** Third parties should have least privilege

Design Principle 2 — Separation of Duties

No Single Point of Control

Definition:

"*A significant task that involves sensitive information should require at least two people to complete.*"

Why It Matters:

- **Prevents fraud** — One person cannot complete a crime alone
- **Detects errors** — Another person reviews the work
- **Reduces risk** — No single point of failure or compromise

Real-World Example:

Bank Cashier's Check

- Person 1: Prepares the check
- Person 2: Signs the check
- Person 3: Issues the check
- **Without separation:** One person could write checks to themselves
- **With separation:** Requires collusion of multiple people

Separation of Duties — Variations

Related Controls

Two-Person Control:

- Two individuals review and approve each other's work
- Both must complete their tasks before proceeding
- **Example:** Nuclear launch requires two keys

Job Rotation:

Employees rotate through different roles

Benefits:

- Detects ongoing fraud
- Reduces dependency on single individuals
- Cross-trains employees

Mandatory Vacations:

- All employees must take at least one week off
- **Purpose:** Allows auditing of work
- **Why fraudsters resist:** Fear of detection

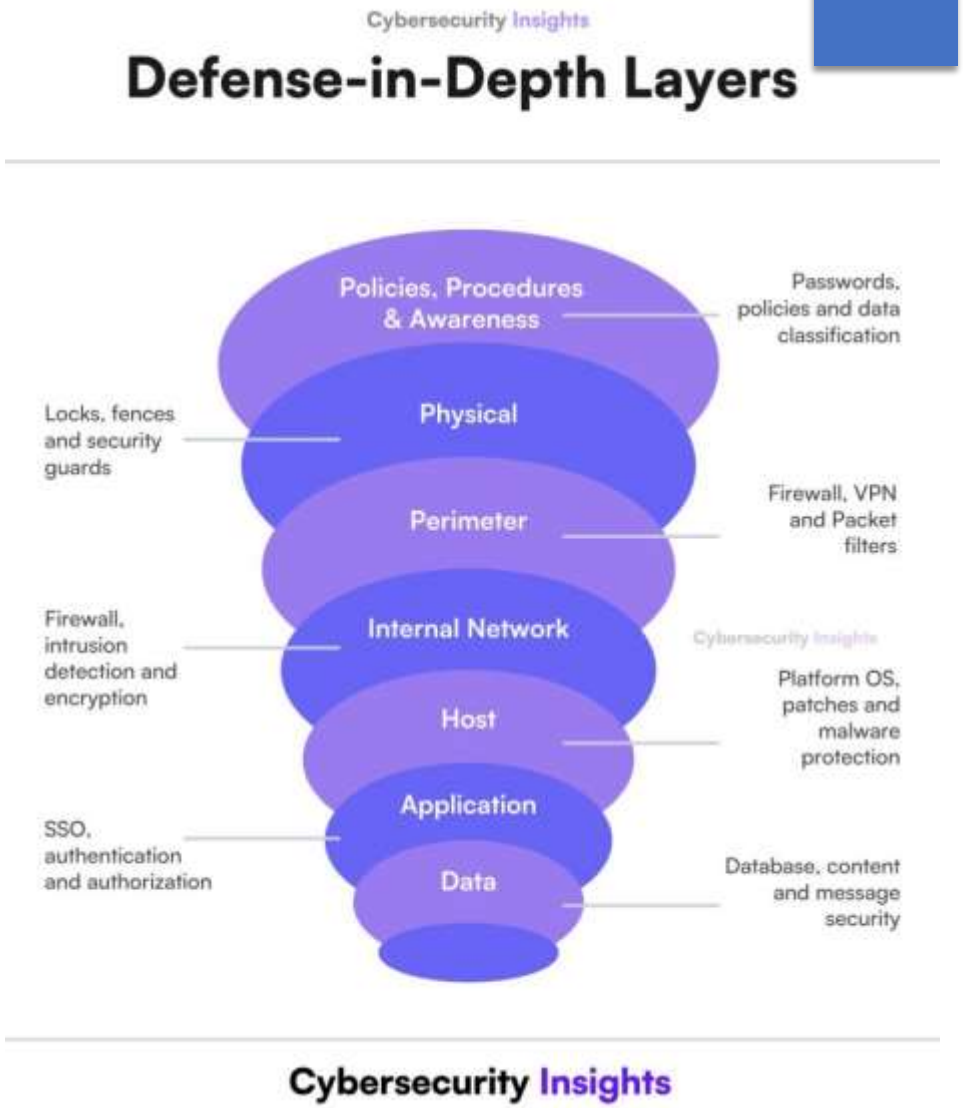
Real-World Example:

Enron/Arthur Andersen

- Arthur Andersen auditors also provided consulting services
- **Conflict of interest:** Auditors had incentive to overlook problems
- **Result:** Enron bankruptcy, Andersen dissolution
- **Lesson:** Separation of duties prevents conflicts of interest

Design Principle 3 — Defense in Depth

- "Implement multiple layers of security controls and safeguards so that the failure of one system does not compromise the security of information.“



Defense in Depth — Real-World Example

The Castle Approach

Medieval Castle Defense:

Moat — First obstacle

Outer Wall — Second barrier

Inner Wall — Third barrier

Keep — Final defense

Guards — Human element

Modern Network Defense:

Layer	Castle Equivalent	Network Equivalent
1	Moat	Perimeter firewall
2	Outer Wall	DMZ, IDPS
3	Inner Wall	Internal firewalls, segmentation
4	Keep	Host-based security, encryption
5	Guards	Security awareness, monitoring

Real-World Example:

Defense in Depth Failure — Target (20

Layer 1: Firewall — Compromised via vendor credentials

Layer 2: Network segmentation — Absent

Layer 3: IDPS — Alerts ignored

Layer 4: Data encryption — Not implemented at rest

Result: 40 million records stolen

Design Principle 4 — Fail-Safe Defaults

Deny by Default

Definition:

"Base access decisions on permission rather than exclusion."

Two Approaches:

Approach	Description	Security Level
Fail-Safe (Deny by Default)	Everything is denied unless explicitly allowed	High
Fail-Open (Allow by Default)	Everything is allowed unless explicitly denied	Low

Real-World Example:

Firewall Rules

- **Bad Practice:** Allow all traffic, block specific bad traffic
- **Good Practice:** Block all traffic, allow specific good traffic
- **Why:** Impossible to know all bad traffic, but possible to know all good traffic

Real-World Example:

Hotel Door Locks

- **Fail-Safe Lock:** Unlocks when power fails (safety first)
- **Fail-Secure Lock:** Remains locked when power fails (security first)
- **Which is right?** Depends on context

- Fire exit → Fail-safe
- Weapons storage → Fail-secure

Fail-Safe Defaults — Implementation

Applying Fail-Safe Defaults

System Configuration:

System	Fail-Safe Configuration
Firewall	Deny all, allow specific
Database	No access, grant specific permissions
File System	No access, grant specific rights
Network	Block all, allow specific ports
Application	Disable all features, enable specific

Real-World Example:

AWS S3 Bucket Misconfiguration

- **Default:** Buckets are private (fail-safe)
- **Misconfiguration:** Administrators made buckets public
- **Result:** Data breaches at Verizon, Accenture, Dow Jones
- **Lesson:** Fail-safe defaults only work if not overridden

Real-World Example:

Mirai Botnet (2016)

- **Target:** IoT devices with default passwords
- **Default:** Devices shipped with admin/admin credentials
- **Attack:** Botnet enslaved 600,000+ devices
- **Impact:** Major DDoS attacks
- **Lesson:** Fail-safe defaults must include unique credentials

Design Principle 5 — Complete Mediation

Check Every Access

Definition:

"Every access to every object must be checked for authority."

Key Concepts:

No caching of access decisions — Check every time

No bypass mechanisms — All paths must be checked

No exceptions — Even "trusted" users must be verified

Real-World Example:

The Hotel Room Key

Scenario: Hotel gives you a key card for your room

Complete Mediation: Key card must work for YOUR room only

Failure: Key card works for ALL rooms

Result: Security breach, guest safety at risk

Real-World Example:

Web Application Access Control

Bad Practice: Check authentication at login only

Good Practice: Check authorization on EVERY request

Attack: Session hijacking, privilege escalation

Prevention: Continuous verification

Complete Mediation — Real-World Failures

When Mediation Fails

1. Cached Credentials Attack

Scenario: System caches credentials after first login

Attack: Attacker uses cached credentials without re-authentication

Example: Browser saved passwords

Prevention: Re-authenticate for sensitive operations

2. Direct Object Reference

Scenario: Web application uses predictable URLs

Example: example.com/user/1234/profile

Attack: Change 1234 to 1235 to access another user's profile

Prevention: Check authorization on every request

3. Privilege Escalation

Scenario: User with limited privileges finds a way to gain admin rights

Example: Exploiting a vulnerability in a service running as root

Prevention: Complete mediation at all levels

Real-World Example:

US Office of Personnel Management (OPM) Breach (2015)

Impact: 21.5 million records

Cause: Incomplete mediation — attackers moved laterally

Lesson: Every access must be verified

Design Principle 6 — Secure-by-Default Design

Security Out of the Box

Definition:

"Systems should be secure in their default configuration, without requiring users to enable security features."

The Problem:

- Many systems ship with security disabled
- Users must manually configure security
- Most users don't change defaults
- **Result:** Widespread vulnerabilities

Real-World Examples:

System	Default Problem	Result
Routers	Default admin/admin	Botnet recruitment
Databases	No password	Data exposure
Cloud Storage	Public by default	Data leaks
Web Servers	Directory listing enabled	Information disclosure
IoT Devices	Telnet enabled	Mirai botnet

Secure-by-Default — Best Practices

Making Security the Default

Design Principles:

1. **Security enabled by default**
2. **Require user action to disable security**
3. **Warn users about security implications**
4. **Provide secure configuration templates**
5. **Regular security updates**

Real-World Example:

Apple iOS Security

- **Default:** Encryption enabled, passcode required
- **Default:** App sandboxing
- **Default:** Secure boot
- **Result:** Most secure consumer mobile OS

Real-World Example:

Windows 10 Security

- **Default:** Windows Defender enabled
- **Default:** Firewall enabled
- **Default:** Automatic updates
- **Result:** Significant reduction in malware infections

Real-World Example:

Google Chrome

- **Default:** Sandboxing
- **Default:** Auto-updates
- **Default:** HTTPS warnings
- **Result:** Most secure browser

Minimizing Attack Surface — Practical Steps

- Reducing the Attack Surface
- Network Level:
  - Close unused ports
  - Disable unused protocols
  - Segment networks
  - Use firewalls effectively
- System Level:
  - Uninstall unused software
  - Disable unused services
  - Remove unused accounts
  - Apply least privilege
- Application Level:
  - Disable unused features
  - Remove sample files
  - Disable directory listing
  - Use secure coding practices
- Real-World Example:
- Docker Container Security
  - Default: Minimal base image
  - Best Practice: Distroless images
  - Result: Fewer components = fewer vulnerabilities
  - Example: Alpine Linux containers have 90% fewer vulnerabilities than Ubuntu containers

Design Principles — Summary Matrix

All Principles Working Together

Principle	Core Idea	Real-World Application
Least Privilege	Minimum access needed	User roles, database permissions
Separation of Duties	No single point of control	Two-person approval, job rotation
Defense in Depth	Multiple layers	Firewalls, IDPS, encryption
Fail-Safe Defaults	Deny unless allowed	Firewall rules, access controls
Complete Mediation	Check every access	Authorization on every request
Secure-by-Default	Secure out of the box	Default encryption, auto-updates
Minimize Attack Surface	Reduce entry points	Close ports, disable services

Key Insight:

These principles are **interdependent**. Implementing one without the others leaves gaps.

Threat Categories

The 14 General Threat Categories

#	Category	Examples
1	Compromises to IP	Piracy, copyright infringement
2	Software Attacks	Viruses, worms, DoS
3	Deviations in QoS	ISP outages, power failures
4	Espionage/Trespass	Unauthorized access
5	Forces of Nature	Fire, flood, earthquake
6	Human Error	Accidents, mistakes
7	Information Extortion	Blackmail, disclosure
8	Missing Policy	No security policy
9	Missing Controls	No firewall
10	Sabotage/Vandalism	Destruction of systems
11	Theft	Equipment or data theft
12	Hardware Failures	Equipment failure
13	Software Failures	Bugs, code problems
14	Obsolescence	Outdated technology

Attack Types — Overview

Classifying Attacks

By Intent:

Type	Description	Example
Active	Directly alters system or data	DoS, malware
Passive	Monitors without alteration	Eavesdropping, sniffing

By Origin:

Type	Description	Example
Direct	From attacker's own system	Hacking from home
Indirect	Via compromised system	Botnet, zombie

By Method:

Type	Description	Example
Malware	Malicious software	Virus, worm, Trojan
Social Engineering	Manipulating people	Phishing, pretexting
Technical	Exploiting vulnerabilities	Buffer overflow, SQL injection
Physical	Physical access	Tailgating, theft

Passive vs. Active Attacks

Understanding the Difference

Passive Attacks:

- **Monitor and collect** information
- **Do not alter** systems or data
- **Hard to detect** (no traces)
- **Focus on prevention** (encryption)

Attack	Description	Example
Eavesdropping	Listening to communications	Wiretapping
Sniffing	Capturing network packets	Wireshark
Traffic Analysis	Analyzing communication patterns	Metadata analysis
Shoulder Surfing	Looking over someone's shoulder	Reading screen

Active Attacks:

- **Alter** systems or data
- **Disrupt** operations
- **Easier to detect** (leaves traces)
- **Focus on detection and response**

Attack	Description	Example
Denial of Service	Disrupt availability	Flooding server
Malware	Infect systems	Virus, ransomware
Spoofing	Forge identity	IP spoofing
Man-in-the-Middle	Intercept and modify	Session hijacking

Malware — Types and Characteristics

Malicious Software

Types of Malware:

Type	Description	Replication	Example
Virus	Attaches to files, requires user action	Yes	Melissa, ILOVEYOU
Worm	Self-replicating, no user action	Yes	Morris Worm, Code Red
Trojan Horse	Disguised as legitimate software	No	Happy99
Ransomware	Encrypts files, demands payment	No	WannaCry, Petya
Spyware	Collects information secretly	No	Keyloggers
Adware	Displays unwanted ads	No	Pop-ups
Rootkit	Hides presence, maintains access	No	Sony BMG rootkit
Logic Bomb	Triggers on specific condition	No	Disgruntled employee

Malware — Real-World Examples

Notable Malware Attacks

1. Morris Worm (1988)

Creator: Robert Morris Jr.

Method: Exploited sendmail and finger vulnerabilities

Impact: 6,000 computers infected (10% of Internet)

Cost: $200 per site, $10-100 million total

Lesson: First major Internet worm

2. ILOVEYOU (2000)

Method: Email attachment "LOVE-LETTER-FOR-YOU.txt.vbs"

Impact: 10% of all Internet-connected computers

Cost: $15 billion

Lesson: Social engineering + malware = devastating

Notable Malware Attacks

3. WannaCry (2017)

Method: EternalBlue exploit (NSA leak)

Impact: 200,000+ computers in 150 countries

Cost: $4 billion+

Lesson: Patch management is critical

4. NotPetya (2017)

Method: Supply chain attack via Ukrainian accounting software

Impact: $10 billion+ in damages

Target: Maersk, FedEx, Merck

Lesson: Supply chain security matters

Phishing — The Human Attack

Deceiving Users

Definition:

"An attempt to obtain personal or financial information using fraudulent means, usually by posing as a legitimate entity."

Types of Phishing:

Type	Description	Target
Mass Phishing	Generic emails to many recipients	General public
Spear Phishing	Targeted emails to specific individuals	Executives, admins
Whaling	Targeting senior executives	CEOs, CFOs
Vishing	Voice phishing (phone calls)	Phone users
Smishing	SMS phishing (text messages)	Mobile users
Clone Phishing	Copying legitimate emails	Existing relationships

Real-World Example:

Google/Facebook Phishing (2013-2015)

- **Method:** Fake invoices from legitimate vendors
- **Target:** Finance departments
- **Loss:** $100 million
- **Lesson:** Even tech giants can be phished

Phishing — Recognizing the Signs

How to Spot a Phishing Attack

Common Indicators:

- **Urgency** — "Act now or your account will be closed"
- **Threats** — "Your account has been compromised"
- **Too good to be true** — "You've won a prize"
- **Generic greetings** — "Dear Customer"
- **Suspicious sender** — Mismatched email address
- **Links** — Hover to see actual URL
- **Attachments** — Unexpected files
- **Poor grammar** — Spelling and syntax errors
- **Requests for information** — Passwords, credit cards
- **Unusual sending time** — 3 AM emails

Real-World Example:

Twitter Bitcoin Scam (2020)

- **Method:** Compromised Twitter accounts of Elon Musk, Barack Obama, Bill Gates
- **Message:** "Send Bitcoin, get double back"
- **Loss:** $120,000 in Bitcoin
- **Lesson:** Even verified accounts can be compromised

Social Engineering

Manipulating People

Definition:

"The process of using social skills to convince people to reveal access credentials or other valuable information."

Techniques:

Real-World Example:

Kevin Mitnick

- **Method:** Social engineering, not technical hacking
- **Success:** Accessed Pentagon, Pacific Bell, FBI
- **Quote:** "People are the weakest link"
- **Lesson:** Social engineering bypasses all technical controls

Technique	Description	Example
Pretexting	Creating a false scenario	"I'm from IT, I need your password"
Tailgating	Following authorized person	Entering behind badge holder
Shoulder Surfing	Looking over shoulder	Reading passwords
Dumpster Diving	Searching trash	Finding sensitive documents
Quid Pro Quo	Offering something for information	"Free gift for survey"
Baiting	Leaving infected media	USB drives in parking lot

Social Engineering — Defense

Protecting Against Human Attacks

Defense Strategies:

Security Awareness Training

- Regular training sessions
- Simulated phishing exercises
- Real-world examples

Verification Procedures

- Call back to verify requests
- Use known phone numbers
- Don't trust caller ID

Access Controls

- Badge required for entry
- Escort visitors
- Challenge unknown individuals

Clean Desk Policy

- Lock documents
- Clear whiteboards
- Shred sensitive papers

Incident Reporting

- Report suspicious activity
- No punishment for reporting
- Learn from mistakes

Real-World Example:

RSA SecurID Breach (2011)

Method: Spear phishing emails with Excel attachment

Impact: SecurID tokens compromised

Cost: $66 million

Lesson: Even security companies can be socially engineered

Password Attacks

Cracking Authentication

Types of Password Attacks:

Real-World Example:

RockYou Breach (2009)

- **Impact:** 32 million passwords leaked
- **Most common:** 123456, password, 12345
- **Lesson:** Weak passwords are everywhere

Attack	Description	Time Required
Brute Force	Try every combination	Hours to years
Dictionary	Try common words	Minutes to hours
Rainbow Table	Precomputed hashes	Seconds
Credential Stuffing	Use leaked passwords	Seconds
Password Spraying	Try common passwords	Minutes
Shoulder Surfing	Watch password entry	Seconds
Keylogging	Record keystrokes	Real-time

Password Attacks — Defense

Protecting Passwords

Best Practices:

Strong Password Policy

- Minimum 8 characters (12+ preferred)
- Mix of uppercase, lowercase, numbers, symbols
- No dictionary words

Multi-Factor Authentication (MFA)

- Something you know (password)
- Something you have (token)
- Something you are (biometric)

Account Lockout

- Lock after 3-5 failed attempts
- Temporary lockout (15-30 minutes)

Password Hashing + Salting

- Never store plaintext passwords
- Use strong hashing (bcrypt, Argon2)
- Add random salt

Password Managers

- Generate strong passwords
- Store securely
- Never reuse passwords

Real-World Example:

Colonial Pipeline (2021)

Method: Compromised VPN password

Impact: $4.4 million ransom, fuel shortage

Lesson: MFA is essential

Denial-of-Service (DoS) Attacks

1. **Information security** is essential for protecting organizational assets
2. **Information** = Processed data with meaning
3. **Information systems** = People, procedures, data, software, hardware, networks
4. **Security concepts** work together:
   - **Assets** need protection from **threats**
   - **Vulnerabilities** can be exploited in **attacks**
   - **Risk** is the probability of loss
   - **Controls** reduce risk to acceptable levels

Denial-of-Service (DoS) Attacks

Disrupting Availability

Definition:

"An attack that sends a large number of connection or information requests to overwhelm a target, making it unable to respond to legitimate requests."

Types of DoS:

Type	Description	Example
Volumetric	Flood with traffic	UDP flood
Protocol	Exploit protocol weaknesses	SYN flood
Application	Target application layer	HTTP flood
Distributed (DDoS)	Multiple sources	Botnet attack

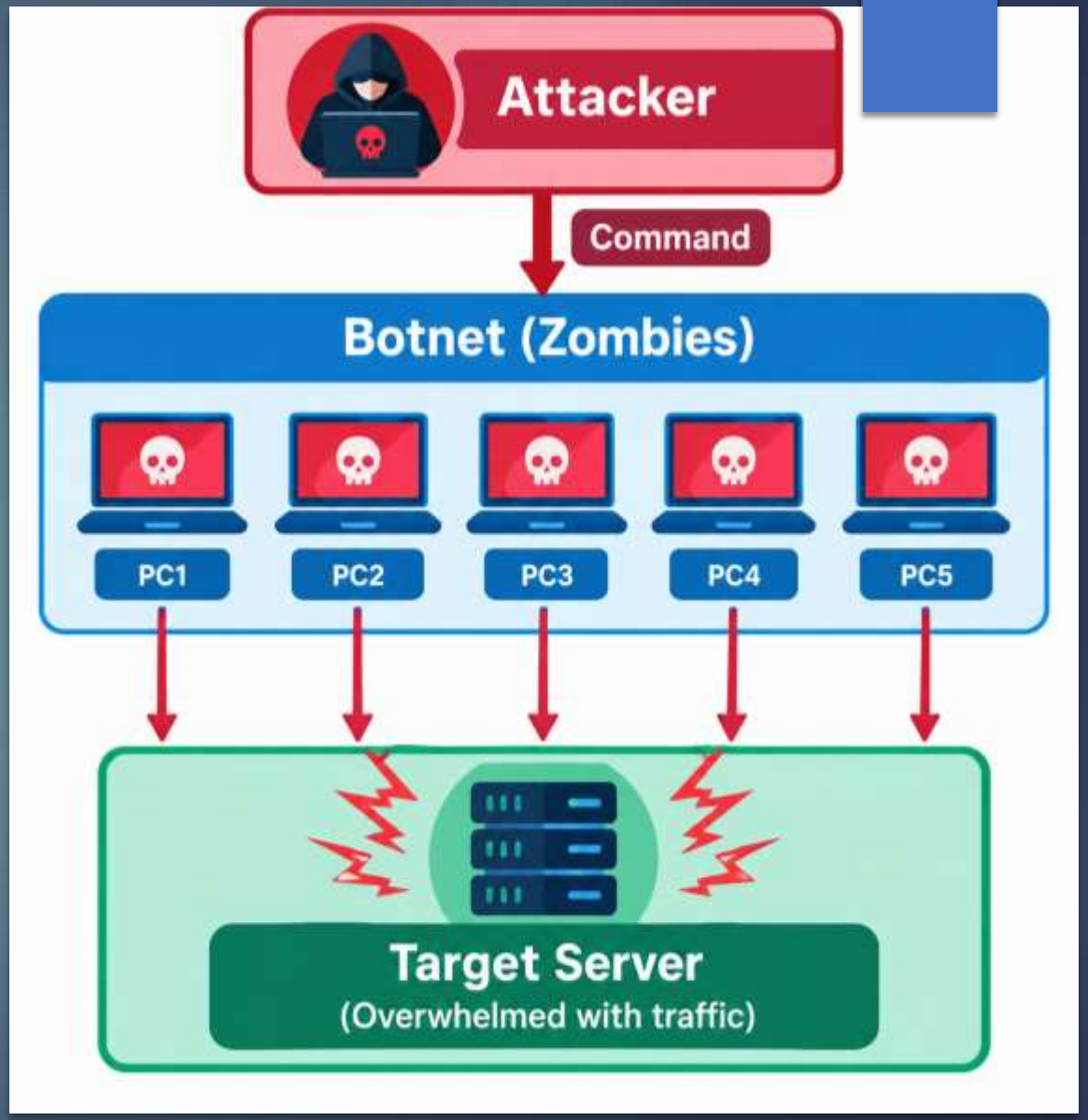
Real-World Example:

Mafiaboy (2000)

- **Target:** Amazon, CNN, eBay, Yahoo
- **Method:** DDoS
- **Impact:** Millions in lost revenue
- **Attacker:** 15-year-old
- **Lesson:** Low skill, high impact

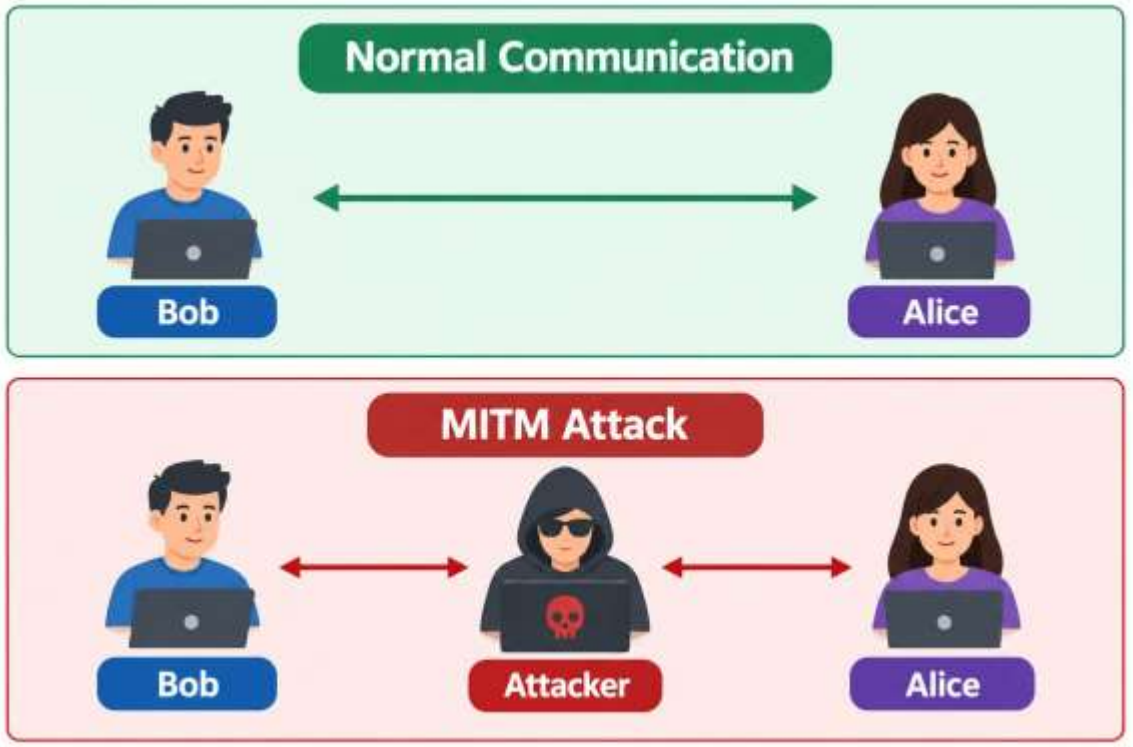
Distributed Denial-of-Service (DDoS)

- The Power of Many
- How DDoS Works:
- Real-World Example:
- Dyn DNS Attack (2016)
  - Method: Mirai botnet (IoT devices)
  - Impact: Twitter, Netflix, Reddit, GitHub
  - Lesson: IoT devices are vulnerable



Man-in-the-Middle (MITM) Attacks

- Intercepting Communications
- Definition:
- "An attack where the attacker secretly intercepts and potentially alters communications between two parties."
- How MITM Works:
- Types of MITM:
- Real-World Example:
- Superfish (2015)
  - Method: Pre-installed adware on Lenovo laptops
  - Impact: MITM all HTTPS traffic
  - Lesson: Supply chain trust matters



Man-in-the-Middle — Defense

Preventing MITM

Defense Strategies:

Encryption

- Use HTTPS everywhere
- Verify certificates
- Use VPNs

Certificate Pinning

- Bind certificate to specific server
- Prevent fake certificates

MFA

- Hard for attacker to replay
- Token-based authentication

Network Security

- Avoid public Wi-Fi for sensitive tasks
- Use cellular data or VPN
- Monitor for ARP spoofing

User Awareness

- Check for HTTPS
- Look for certificate warnings
- Don't ignore browser warnings

Real-World Example:

Firesheep (2010)

Method: Firefox extension to hijack sessions

Target: Public Wi-Fi users

Impact: Facebook, Twitter, Amazon sessions stolen

Lesson: HTTPS everywhere is essential

Type	Description	Example
Wi-Fi Eavesdropping	Fake hotspot	Coffee shop Wi-Fi
Session Hijacking	Steal session cookie	Firesheep
IP Spoofing	Forge source address	ARP poisoning
SSL Stripping	Downgrade HTTPS to HTTP	sslstrip

Passive Attacks

Monitoring Without Alteration

Characteristics:

- **Hard to detect** — No traces left
- **Focus on prevention** — Encryption is key
- **Information gathering** — For future attacks

Types of Passive Attacks:

Attack	Description	Example
Eavesdropping	Listening to communications	Wiretapping
Sniffing	Capturing network packets	Wireshark
Traffic Analysis	Analyzing patterns	Metadata
Shoulder Surfing	Observing screen	Looking over shoulder
Dumpster Diving	Searching trash	Finding documents

Real-World Example:

NSA PRISM (2013)

- **Method:** Mass surveillance program
- **Impact:** Collected data from Google, Facebook, Apple
- **Lesson:** Passive attacks can be large scale

Passive Attacks — Defense

Protecting Against Passive Attacks

Defense Strategies:

Encryption

- Encrypt data at rest and in transit
- Use strong encryption (AES-256)

Secure Communication

- Use VPNs
- Use HTTPS
- Use encrypted email

Physical Security

- Privacy screens
- Locked cabinets
- Shred documents

Network Security

- Switched networks (not hubs)
- VLANs
- Network monitoring

Awareness

- Train employees
- Report suspicious activity
- Clean desk policy

Real-World Example:

WEP Cracking

Method: Passive sniffing of wireless traffic

Impact: WEP encryption broken in minutes

Lesson: Weak encryption is worse than none

Active Attacks

Altering Systems and Data

Characteristics:

- **Easier to detect** — Leaves traces
- **Focus on detection and response**
- **Direct impact** — Alters systems

Types of Active Attacks:

Attack	Description	Example
DoS/DDoS	Disrupt availability	Flooding
Malware	Infect systems	Virus, ransomware
Spoofing	Forge identity	IP spoofing
MITM	Intercept and modify	Session hijacking
SQL Injection	Inject malicious SQL	Database attack
XSS	Inject client-side scripts	Web attack

Real-World Example:

Sony Pictures (2014)

- **Method:** Destructive malware
- **Impact:** Data wiped, emails leaked
- **Cost:** $100 million+
- **Lesson:** Active attacks can be devastating

Active Attacks — Defense

Protecting Against Active Attacks

Defense Strategies:

Firewalls and IDPS

- Detect and block attacks
- Monitor for suspicious activity

Patch Management

- Keep systems updated
- Test patches before deployment

Access Controls

- Least privilege
- Strong authentication

Incident Response

- Plan for attacks
- Detect, respond, recover

Backups

- Regular backups
- Test restoration
- Offsite storage

Real-World Example:

NotPetya (2017)

Method: Supply chain attack

Impact: $10 billion+ damages

Lesson: Defense in depth is essential

Cyber Crime vs. Ethical Hacking

Understanding the Difference

Cyber Crime:

- **Unauthorized** access
- **Malicious** intent
- **Personal gain** or harm
- **Illegal** — subject to prosecution
- **No authorization**

Ethical Hacking:

- **Authorized** access
- **Defensive** intent
- **Improve security**
- **Legal** — with proper authorization
- **Written authorization** required

Key Difference:

Authorization — Cyber criminals act without permission; ethical hackers act with permission.

Ethical Hacking — The Profession

What Ethical Hackers Do:

1. **Footprinting** — Gather information
2. **Scanning** — Identify live systems
3. **Enumeration** — Identify services
4. **Vulnerability Analysis** — Find weaknesses
5. **Exploitation** — Attempt to compromise
6. **Reporting** — Document findings

Certifications:

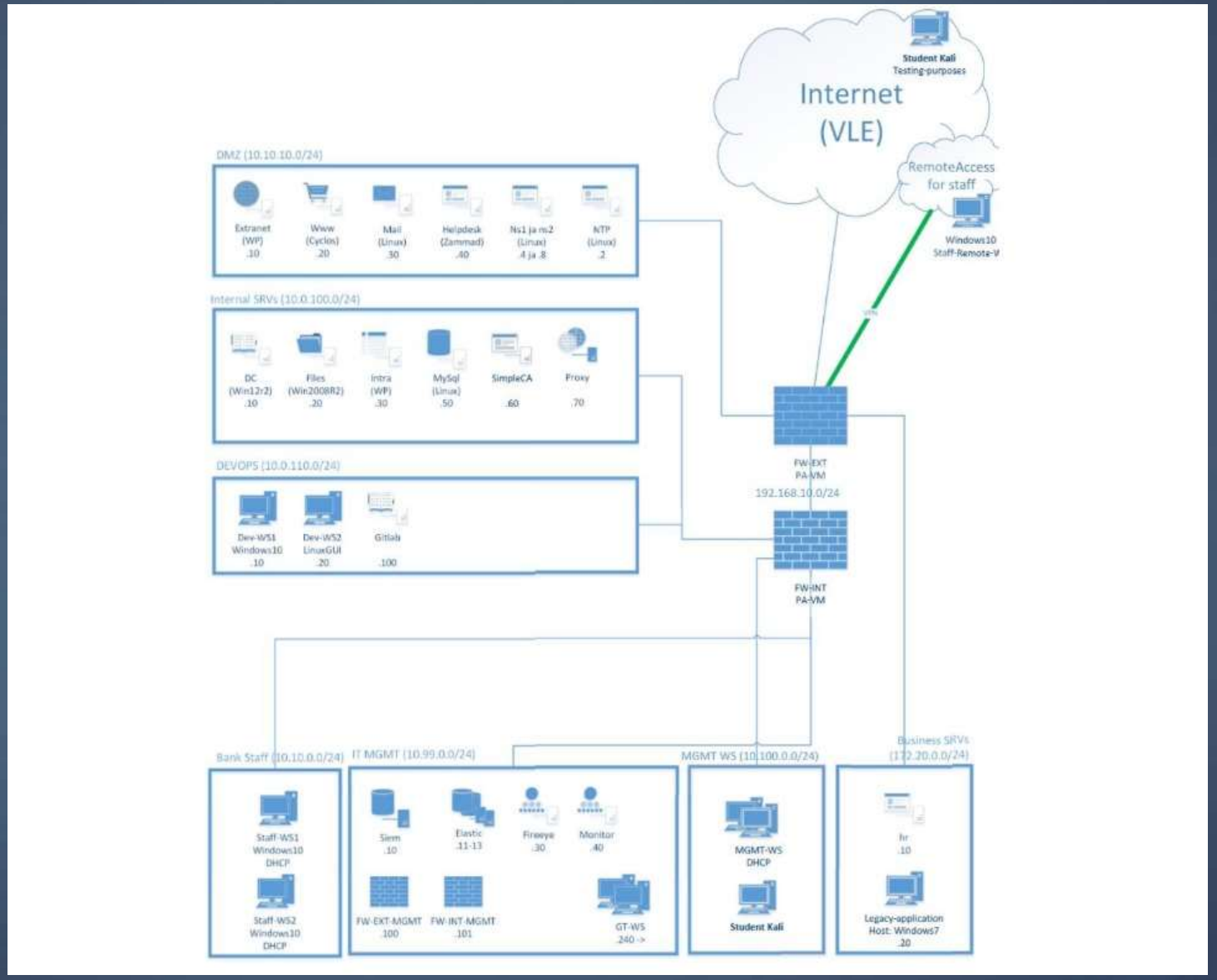
Certification	Organization	Focus
CEH	EC-Council	Ethical hacking
OSCP	Offensive Security	Hands-on pentesting
GPEN	SANS/GIAC	Penetration testing
CPT	IACRB	Penetration testing

Real-World Example:

Penetration Testing Success

- **Company:** Fortune 500 financial services
- **Finding:** SQL injection in online banking

Sample Enterprise Network Diagram



Legal and Ethical Issues

The Legal Framework

Key Laws:

Ethical Principles:

1. **Protect society** — Common good
2. **Act honorably** — Honest and just
3. **Provide competent service** — Diligent and skilled
4. **Advance the profession** — Protect and promote

Law	Year	Focus
Computer Fraud and Abuse Act	1986	Unauthorized access
Electronic Communications Privacy Act	1986	Wiretapping
Health Insurance Portability and Accountability Act (HIPAA)	1996	Health data
Gramm-Leach-Bliley Act	1999	Financial data
Sarbanes-Oxley Act	2002	Corporate accountability
General Data Protection Regulation (GDPR)	2018	EU privacy

Legal and Ethical — Real-World Cases

- When Ethics and Law Collide

- Case 1: Aaron Swartz (2011-2013)
- Action: Downloaded academic articles from JSTOR
- Charge: Computer Fraud and Abuse Act
- Result: Suicide while facing 35 years
- Debate: Overly harsh prosecution?

- Case 2: Edward Snowden (2013)
- Action: Leaked NSA surveillance documents
- Charge: Espionage Act
- Result: Exiled in Russia
- Debate: Whistleblower or traitor?

- Case 3: Marcus Hutchins (2017)
- Action: Stopped WannaCry, but wrote malware as teen
- Charge: Creating Kronos malware
- Result: Plea deal, no prison
- Debate: Reformed hacker or criminal?
- Lesson:
- The line between ethical hacking and cyber crime can be blurry. Authorization is key.

Legal and Ethical — Real-World Cases

When Ethics and Law Collide

Case 1: Aaron Swartz (2011-2013)

Action: Downloaded academic articles from JSTOR

Charge: Computer Fraud and Abuse Act

Result: Suicide while facing 35 years

Debate: Overly harsh prosecution?

Case 2: Edward Snowden (2013)

Action: Leaked NSA surveillance documents

Charge: Espionage Act

Result: Exiled in Russia

Debate: Whistleblower or traitor?

Case 3: Marcus Hutchins (2017)

Action: Stopped WannaCry, but wrote malware as teen

Charge: Creating Kronos malware

Result: Plea deal, no prison

Debate: Reformed hacker or criminal?

Lesson:

The line between ethical hacking and cyber crime can be blurry. Authorization is key.

Social Issues in Information Security

The Broader Context

Privacy vs. Security:

- **Government surveillance** — NSA, GCHQ
- **Corporate tracking** — Google, Facebook
- **Encryption debate** — Apple vs. FBI

Digital Divide:

- **Access inequality** — Who has technology?
- **Skills gap** — Who understands security?
- **Economic impact** — Who can afford protection?

Cyber Warfare:

- **Nation-state attacks** — Stuxnet, NotPetya
- **Critical infrastructure** — Power grids, water systems
- **Election interference** — 2016 US election

Real-World Example:

Apple vs. FBI (2016)

- **Issue:** FBI wanted Apple to unlock iPhone
- **Apple's Position:** Would create backdoor for everyone
- **Result:** FBI found another way
- **Lesson:** Security vs. privacy is an ongoing debate

Thank you